XSS: De nombreux types de fichier peuvent nous permettre d'introduire une dans une application web en y téléversant des version "payloader", ça peut être dernment les fichiers HTML, les métadonnés d'une image si le site web les réaff les fichiers XML ou encore SVG qui sont basé sur XML...

XXE: (Pour XML external Entity) une faille de sécurité pouvant toucher les appli on web convertissant des fichiers XML. Elle se produit lorsque un analyseur XML configuré traite des références à des entités externes au sein d'un fichier XML en par un utilisateur malveillant. (Cela peux mener à des SSRF, lectures de fi locaux ou encore DOS)

DOS: plusieurs DOS peuvent potentiellement être réalisés, ZIP Bomb, les zip imb es menant à des Pétaoctets de données, L'attaque par inondation de pixels et enfin peu trouver un moyen propre à la configuration vulnérable du system cible.

Diverses payloads SQL, XSS, LFI et autres peuvent être testés directement par nom du fichier, NB: pour trouver ou exactement sont uploader les fichiers on peu sayer entre autre de forcer un message d'erreur (avec nom trop long ? upload du même nom etc...)
Pour les system windows on peu aussi entrainer une erreur en nommant n fichiers avec des noms réservés comme (CON, COM1, LPT1 ou NUL).

Il y a des vulnérabilités avancés de téléversement de fichiers qui peuvent avoir lieu d'opérations sur les fichiers tel que l'encodage vidéo, la supression ou le renom ge d'un fichier, etc, leur découverte nécessite des compétences plus avancés...



Command Injections

Catégorie : ⚔ Offensif
Difficulté : Médium, Tiers II
Durée Estimée : 6 Heures

Introduction Aux Injections De Commandes:

Les vulnérabilité d'injection trône en 3 ème place du top 10 de l'O SP, globalement une injection à lieu lorsque une entrée utilisateur mal échappé menant à diverses actions malveillante...
Ici nous verrons principalement les vulnérabilité d'injection de command system...
Tout les serveurs disposent d'un langage permettant d'exécuter des commandes system.... même JS et PHP possède des fonctions de commandes system.

Detection Des Injections De Commandes basiques:

Pour découvrir une telle vulnérabilité le facteur numéro 1 est la revue de ...tion dans une application web par exemple cela va se faire via Burp
Ce module se concentre sur les injections de commande vraiment très basiq (en gros les données user sont passer en paramètre à des commandes s tems sans aucune sanitization préalables...
Il faux utiliser un operateur pour chainer (&&, ;, |, ||) les command